

## Implemented Controls

- TLS (1.3)
- Firewalls
- Rate Limiter
- Key Vault (Separate server)
- Role Based Access Control
- JWT
- MFA (Multi Factor Authorisation)
- Hashing
- Audit logs(Separate Server)

| <i>Existing Control</i>     | <i>Annex A Mapping</i>                      | <i>Gap Identified</i>                                         | <i>Compensating Control</i>                                           | <i>Threats Mitigated Against</i>               |
|-----------------------------|---------------------------------------------|---------------------------------------------------------------|-----------------------------------------------------------------------|------------------------------------------------|
| TLS (1.3)                   | A.8.24 Use of Cryptography                  | Potential for downgrade attacks on older browsers.            | Implement HSTS (HTTP Strict Transport Security) headers.+1            | Information Disclosure, Tampering              |
| Firewalls (WAF)             | A.8.22 Segregation in Networks              | Signature-based WAFs may miss "zero-day" exploits.            | Input validation and output encoding at the application level.        | Tampering, Denial of Service                   |
| Rate Limiter                | A.8.26 Application Security Requirements +1 | High-distributed attacks might bypass simple IP-based limits. | Account lockout policies and monitoring failed login attempts.+1      | Denial of Service                              |
| Key Vault (Separate Server) | A.8.24 Use of Cryptography                  | Risk of "root" credential theft to the vault itself.          | Least privilege access policies and managed identities for the API.+1 | Information Disclosure, Elevation of Privilege |
| RBAC                        | A.5.15 Access Control                       | Manual role assignment can lead to human error.               | Audit logging of all privilege changes and role assignments.+2        | Elevation of Privilege, Spoofing               |
| JWT                         | A.8.5 Secure Authentication                 | Token theft via Cross-Site Scripting (XSS).                   | HttpOnly and Secure flags for cookies; short expiration times.+1      | Spoofing, Tampering                            |
| MFA (TOTP)                  | A.8.5 Secure Authentication                 | Users may lose access to their TOTP devices.                  | Secure Identity Recovery process with time-limited reset tokens.      | Spoofing                                       |
| Hashing (bcrypt/Argon2)     | A.8.24 Use of Cryptography +1               | Static salts can be vulnerable if                             | Use of cryptographically secure random salts for                      | Information Disclosure                         |

|                                 |                   |                                                     |                                                                             |                           |
|---------------------------------|-------------------|-----------------------------------------------------|-----------------------------------------------------------------------------|---------------------------|
|                                 |                   | the salt generation is weak.                        | every unique user.                                                          |                           |
| Audit Logs<br>(Separate Server) | A.8.15 Logging +2 | Logs can be deleted by a compromised Admin account. | Hash-protected integrity checks to detect if log files have been altered.+1 | Repudiation,<br>Tampering |